

Análisis Forense Avanzado de Ataques Phishing Basados en el Protocolo HTTP en Entornos de Red

El panorama contemporáneo de la ciberseguridad se encuentra intrínsecamente ligado a la sofisticación de las técnicas de ingeniería social, especialmente aquellas que instrumentalizan el protocolo de transferencia de hipertexto (HTTP) para la exfiltración de datos sensibles. Los ataques de phishing, lejos de ser eventos aislados de engaño superficial, representan hoy en día operaciones multi-etapa que aprovechan las vulnerabilidades estructurales de la arquitectura web y la confianza inherente de los usuarios en los dominios legítimos.¹ En el contexto del análisis forense de redes, el examen de archivos de captura de paquetes (PCAP) constituye la metodología fundamental para reconstruir la interacción entre la víctima y la infraestructura del atacante, permitiendo identificar desde el señuelo inicial hasta la cosecha final de credenciales.³ Este informe técnico detalla los mecanismos, firmas forenses y estrategias de detección de ataques phishing/HTTP, proporcionando una base empírica para la simulación de tráfico malicioso y el entrenamiento de analistas en centros de operaciones de seguridad (SOC).

Arquitectura y Mecanismos del Phishing en la Capa de Aplicación

La efectividad del phishing basado en HTTP radica en su capacidad para operar sobre protocolos estándar que raramente son bloqueados por los cortafuegos perimetrales. Aunque la industria ha migrado masivamente hacia HTTPS, el uso de HTTP en texto claro persiste en aplicaciones internas, configuraciones heredadas y, de manera crítica, en las fases intermedias de redirección donde la encriptación puede ser omitida deliberadamente por el atacante para reducir la latencia o simplificar el despliegue de sus kits de phishing.⁵

El Ciclo de Vida del Ataque desde la Perspectiva de Red

Un ataque de phishing exitoso se desglosa en una serie de fases técnicas que dejan rastros específicos en el tráfico de red. La fase de reconocimiento implica la recolección de inteligencia sobre los objetivos, a menudo utilizando fuentes abiertas (OSINT) o volcados de brechas previas para identificar empleados con privilegios elevados.² Una vez identificado el objetivo, el atacante procede a la ingeniería del "anzuelo", un artefacto psicológico diseñado para provocar urgencia o miedo, como una alerta de seguridad de red o una factura pendiente.¹

La entrega del ataque se materializa comúnmente a través del correo electrónico (SMTP/SMTPS), donde se incluye un enlace malicioso o un archivo adjunto que, al ser ejecutado,

inicia una solicitud HTTP hacia la infraestructura del atacante.² Es en este punto donde el análisis forense de archivos PCAP adquiere su mayor relevancia, permitiendo observar la transición desde el dominio legítimo (a menudo abusado mediante redirecciones abiertas) hacia el servidor de cosecha de credenciales controlado por el adversario.⁴

Fase	Acción Técnica	Evidencia en el PCAP
Entrega	Recepción de correo con enlace malicioso	Paquetes SMTP DATA; consultas DNS hacia servidores de correo. ⁹
Explotación	Usuario hace clic e inicia conexión HTTP	Solicitudes HTTP GET hacia dominios sospechosos o recién registrados. ¹¹
Redirección	Tránsito a través de múltiples saltos	Códigos de estado HTTP 301/302; cambios en el encabezado Location. ¹²
Instalación	Carga del portal de phishing o malware	HTTP GET para binarios (.exe,.dll) o scripts de página. ⁶
Cosecha	Envío de credenciales mediante formularios	Solicitudes HTTP POST con datos en texto claro en el cuerpo del mensaje. ¹⁴
Exfiltración	Comunicación con el centro de control (C2)	Patrones de "beaconing" o latidos constantes hacia IPs externas. ¹⁶

Identificación y Análisis de Firmas Forenses en el Tráfico HTTP

Para reconocer un ataque de phishing en un flujo de tráfico, el analista debe centrarse en las anomalías presentes en los encabezados HTTP y en el comportamiento de las consultas DNS asociadas. Los protocolos de texto plano como HTTP, FTP y Telnet son considerados "minas de oro" para la seguridad, ya que transmiten información sensible sin cifrado, facilitando su interceptación.⁵

Análisis de Encabezados HTTP Críticos

El encabezado User-Agent es uno de los indicadores más reveladores en una investigación forense. Mientras que los navegadores legítimos presentan cadenas estandarizadas y detalladas, las herramientas de ataque y los scripts automatizados suelen utilizar valores genéricos o sospechosos que delatan su naturaleza no humana.¹⁸

Cadena de User-Agent	Implicación Forense	Contexto de Ataque
python-requests/2.25.1	Script automatizado	Escaneo de vulnerabilidades o exfiltración programada. ¹¹
curl/7.68.0	Herramienta de línea de comandos	Descarga manual de payloads o interacción directa con C2. ¹¹
Java/1.8.0_191	Entorno de ejecución Java	Posible explotación de vulnerabilidades tipo Log4j o applets maliciosos. ²¹
lynx/2.8.7rel.1	Navegador de texto	Ataques dirigidos realizados manualmente desde terminales. ²²
Mozilla/4.0 (compatible;...)	Navegador obsoleto	Común en botnets antiguas o malware que emula sistemas heredados (p. ej., Koi Stealer). ¹⁷

Además del User-Agent, el encabezado Referer permite rastrear el origen de una solicitud, identificando si el usuario proviene de un correo electrónico web, una red social o un sitio previamente comprometido.²³ Las discrepancias entre el Host solicitado y el Referer pueden indicar el uso de técnicas de redirección para enmascarar el destino final del tráfico malicioso.

Características Léxicas y Estadísticas de los Dominios Maliciosos

Los dominios utilizados en campañas de phishing suelen exhibir patrones predecibles diseñados para engañar visualmente al usuario. El uso de typosquatting (p. ej., g00gle.com en lugar de google.com) o la creación de subdominios extensos que ocultan el dominio raíz real son tácticas estándar.¹ En el análisis forense, se pueden extraer características estadísticas de las consultas DNS para asignar niveles de riesgo a los dominios detectados.²⁶

Característica del Dominio	Descripción	Indicador de Phishing
Longitud	Cantidad total de caracteres	Los dominios maliciosos suelen ser más largos para incluir marcas legítimas como subdominios. ²⁶
Entropía	Aleatoriedad en la distribución de letras	Una entropía alta sugiere dominios generados algorítmicamente (DGA). ²⁷
Porcentaje Numérico	Proporción de dígitos en la cadena	La inclusión de números aleatorios es común en infraestructuras de phishing desechables. ²⁶
Reputación del TLD	Prestigio del dominio de nivel superior	TLDs como .pw, .top, o .xyz tienen históricamente mayor asociación con malware. ²⁶
Edad del Dominio	Tiempo desde el registro inicial	Los dominios de phishing suelen tener una antigüedad menor a 30 días en el momento del ataque. ¹

Mecanismos de Cosecha de Credenciales y el Uso de HTTP POST

La culminación técnica de un ataque de phishing es la captura de los datos introducidos por la víctima. Este proceso se realiza predominantemente mediante el método HTTP POST, que envía los datos del formulario desde el cliente hacia el servidor del atacante.¹⁴

Estructura de la Solicitud POST Maliciosa

En una captura de paquetes, las solicitudes POST se identifican mediante el filtro de visualización `http.request.method == "POST"`. Al expandir la capa de protocolo HTTP en Wireshark, el analista puede observar los campos del formulario dentro del cuerpo del mensaje.⁶ Es común encontrar rutas de destino como `/login.php`, `/check.php` o `/auth.php`, que son manejadas por scripts en el servidor para procesar y almacenar las credenciales robadas.¹⁴

Un aspecto crítico es la presencia de parámetros ocultos en estas solicitudes. Los atacantes

pueden incluir campos que no son visibles para el usuario pero que proporcionan metadatos adicionales sobre la víctima, como identificadores de sesión, la dirección de correo electrónico pre-poblada desde el enlace inicial o tokens de geolocalización.³⁰ Estos parámetros ayudan al atacante a organizar la información recolectada y a personalizar los ataques subsiguientes.

Ataques de "Navegador en el Navegador" (BitB)

Una evolución sofisticada de la cosecha de credenciales es el ataque Browser-in-the-Browser (BitB). En lugar de redirigir al usuario a un dominio completamente diferente, el atacante utiliza HTML, CSS y JavaScript para simular una ventana emergente de inicio de sesión de un proveedor confiable (como Google o Microsoft) dentro de la página actual.³³ Esta ventana falsa imita perfectamente la interfaz del navegador, incluyendo la barra de direcciones con el candado SSL.³⁵

Desde el punto de vista forense de red, los ataques BitB pueden ser difíciles de detectar porque los datos robados suelen enviarse mediante solicitudes AJAX o fetch() asíncronas que se mezclan con el tráfico legítimo de la página.³⁶ Sin embargo, la inspección detallada puede revelar que la supuesta ventana de SSO es en realidad un elemento IFrame que carga contenido de una IP externa o de un dominio no relacionado con el proveedor de identidad.³⁴ Además, estas ventanas falsas están confinadas por los bordes físicos de la ventana del navegador principal y no pueden moverse fuera de ellos, un comportamiento anómalo que los analistas deben documentar.³⁵

Análisis de Cadenas de Redirección y Abuso de Infraestructura Legítima

Los atacantes modernos raramente dirigen a las víctimas directamente al sitio de phishing. En su lugar, emplean complejas cadenas de redirección que aprovechan la confianza en servicios de terceros.³¹ Este enfoque no solo engaña al usuario, sino que también ayuda a evadir los filtros de seguridad automatizados que pueden no seguir la cadena completa de saltos.¹⁰

El Caso del Abuso de Google Meet y Redirecciones Abiertas

Una campaña analizada recientemente demostró el uso de múltiples capas de redirección utilizando servicios de Google. El enlace inicial utilizaba un punto final de redirección de Google Meet (meet.google.com/linkredirect?dest=), lo que generaba una percepción inmediata de seguridad debido a la validez del certificado SSL y la reputación del dominio.³¹

La cadena de eventos técnica se desarrolla de la siguiente manera:

1. El usuario hace clic en un enlace de confianza aparente en un correo electrónico.
2. La solicitud llega a un servicio legítimo que permite redirecciones externas ("Open Redirect").
3. Se produce un salto intermedio a través de un acortador de enlaces para dificultar el rastreo estático.³¹

4. La víctima llega finalmente a una página de aterrizaje, a menudo un sitio de WordPress comprometido, donde se presenta un desafío CAPTCHA para filtrar bots y dar una falsa sensación de seguridad antes de mostrar el formulario de phishing final.³¹

Este tipo de infraestructura de redirección es más estable que los propios dominios de phishing finales, que rotan rápidamente. Por lo tanto, la detección forense debe centrarse en identificar estos patrones de parámetros recurrentes en las URLs (como v, session, cid) que aparecen temprano en la ejecución de la cadena.¹⁰

Casos de Estudio Reales y Desglose de Capturas de Paquetes maliciosos

El análisis de casos reales permite comprender la secuencia exacta de paquetes que definen una infección. A continuación, se detallan tres escenarios extraídos de investigaciones forenses de campo.

Caso de Estudio 1: Infección por Qakbot (Qbot)

Qakbot es un troyano bancario y un facilitador de ransomware que se distribuye masivamente mediante phishing. Su rastro en el tráfico de red es distintivo, comenzando con la descarga de un binario malicioso y siguiendo con la propagación lateral interna.²⁰

Número de Paquete	Marca de Tiempo	Protocolo	Acción	Detalle Técnico
1721	17:04:23.448	HTTP	GET /86607.dat	Descarga inicial del payload malicioso (DLL). ²⁰
3656	17:04:24.120	HTTP	200 OK	Entrega del binario; encabezado contiene "MZ". ²⁰
55196	19:48:05.332	SMB	Escritura de Archivo	Transferencia lateral del DLL efweioirfbtk.dll. ²⁰

51813	19:48:10.115	SMB	Escritura de Archivo	Transferencia lateral de umtqqzxklrgp.dll. ²⁰
-------	--------------	-----	----------------------	--

La relación causal se establece al verificar que el hash SHA256 del archivo descargado vía HTTP (713207d9d9875ec88d2f3a53377bf8c2d620147a4199eb183c13a7e957056432) coincide plenamente con los archivos escritos posteriormente en otros hosts de la red local a través de SMB.²⁰

Caso de Estudio 2: Ataque de Autenticación Básica HTTP

A pesar de su obsolescencia, la autenticación básica HTTP sigue siendo un objetivo común debido a su simplicidad. En este escenario, un atacante intenta realizar un acceso no autorizado a un servidor administrativo.²²

Campo Forense	Valor Detectado	Significado
Filtro de Búsqueda	http.authorization	Localización de credenciales codificadas. ²²
Sistema Operativo	FreeBSD	Identificado mediante el encabezado Server en la respuesta. ²²
Software de Servidor	Apache/2.2.15	Versión específica con vulnerabilidades conocidas. ²²
User-Agent del Atacante	lynx/2.8.7rel.1	Uso de navegador de consola para ejecución rápida de solicitudes. ²²
Credenciales Capturadas	webadmin:W3b4Dm1n	Decodificación Base64 de la cadena capturada. ²²

Este ataque se caracteriza por una serie de solicitudes repetitivas con diferentes valores de autorización, lo que indica un intento de fuerza bruta o el uso de credenciales previamente comprometidas en otros servicios.²²

Caso de Estudio 3: Beaconing de C2 con Koi Stealer

El malware Koi Stealer utiliza HTTP para mantener la persistencia y recibir instrucciones desde

su servidor de comando y control (C2). La firma forense más clara es el patrón temporal de las conexiones.¹⁷

El host infectado (172.17.0.99) envía solicitudes periódicas al servidor C2 (79.124.78.197). Estas solicitudes utilizan el método POST hacia la URI /foots.php y contienen un cuerpo de mensaje con una estructura definida: <Código>|<UUID>|<ID de Sesión>.¹⁷

Patrón de Carga Útil (POST)	Código	Frecuencia Detectada
`101	30168213-3be0-a751-...	5LHtVruc
`111	30168213-3be0-a751-...	XHfhYxOt
`102	30168213-3be0-a751-81a0-cf3b228c8654`	102

El análisis del "Time Delta" en Wireshark permite confirmar que estas conexiones ocurren en intervalos matemáticamente precisos de 60 segundos, una anomalía que no corresponde al comportamiento de navegación humano y que es fundamental para la detección de troyanos de acceso remoto (RAT).¹⁶

Técnicas de Análisis en Wireshark para Investigadores del SOC

El dominio de los filtros de visualización y las herramientas internas de Wireshark es esencial para procesar grandes capturas de paquetes y extraer información accionable.⁶

Filtros de Visualización Avanzados para Phishing

El uso de operadores lógicos permite combinar criterios para refinar la búsqueda de tráfico malicioso. Por ejemplo, para buscar solicitudes POST que no vayan dirigidas a puertos estándar, o para identificar el uso de credenciales en texto plano en protocolos variados.⁴⁰

- `http.request.method == "POST" &&!(tcp.port == 80)` : Busca envíos de datos en puertos no convencionales.
- ``http.user_agent contains "python" |`

| http.user_agent contains "curl" : Identifica herramientas de automatización.⁵

- http.response.code == 302 && http.location contains "http://" : Detecta redirecciones hacia sitios externos sin cifrado.¹²
- tcp.flags.syn == 1 && tcp.flags.ack == 0 && tcp.window_size > 1024 : Filtro para detectar escaneos de puertos tipo "TCP Connect" previos a una fase de ataque.⁴²

Reconstrucción de Sesiones y Extracción de Objetos

La función "Follow TCP Stream" permite reensamblar la conversación completa entre el cliente y el servidor, presentando los datos en un formato legible que facilita la identificación de contraseñas, tokens de sesión y el contenido de los archivos descargados.⁶

Para los archivos binarios o scripts de phishing cargados sobre HTTP, la herramienta "Export Objects" (File -> Export Objects -> HTTP) es vital. Permite guardar una copia local del objeto capturado en la red para realizar análisis estáticos, verificar hashes en bases de datos de amenazas como VirusTotal o realizar ingeniería inversa.⁹ En el caso de ataques dirigidos que utilizan SMB para la propagación, se utiliza un procedimiento similar para extraer archivos que el atacante intenta depositar en los recursos compartidos de la red local.⁹

Simulación de Tráfico Malicioso para Modelado de Amenazas

Para entrenar sistemas de inteligencia o tutores virtuales, es necesario disponer de una estructura de datos que simule una captura de paquetes realista. La siguiente tabla presenta una secuencia simulada de un ataque de phishing multi-etapa que culmina en la cosecha de credenciales.

Tabla de Simulación de Captura de Paquetes Phishing/HTTP

No.	Marca de Tiempo	Origen IP	Destino IP	Protocolo	Información / URI	Observación Forense
1	09:15:01.000	10.1.1.50	8.8.8.8	DNS	A meet.google.com	Solicitud de resolución para el señuelo inicial. ³¹

10	09:15:02.120	10.1.1.50	142.250.1.1	HTTP	GET /linkredirect?dest=http://shorter.me/abc	Inicio de la cadena de redirección abusando de Google. ³¹
15	09:15:02.250	10.1.1.50	142.250.1.1	HTTP	302 Found (Location: http://shorter.me/abc)	Salto hacia el acortador de URLs. ¹²
28	09:15:03.440	10.1.1.50	104.21.5.10	HTTP	GET /abc	Resolución del enlace corto en infraestructura compartida. ³⁸
35	09:15:03.610	10.1.1.50	104.21.5.10	HTTP	302 Found (Location: http://wp-compromised.net/login)	Redirección final hacia la página de aterrizaje. ⁴³
50	09:15:05.100	10.1.1.50	185.151.30.5	HTTP	GET /login	Carga del portal de phishing (sitio comprometido). ¹
102	09:15:20.	10.1.1.50	185.151.3	HTTP	POST	Cosecha

	330		0.5		/auth.php	de Credenciales. ¹⁴
103	09:15:20.330	10.1.1.50	185.151.30.5	HTTP	user=victim@corp.com&password=Secret123&pre=1	Datos en texto claro visibles en el cuerpo de la solicitud. ¹⁵
120	09:15:22.000	10.1.1.50	142.250.1.1	HTTP	GET /legit-login	Redirección final al sitio real para reducir sospechas. ²

Este modelo de simulación refleja la complejidad de los ataques modernos, donde la víctima es guiada a través de múltiples saltos técnicos antes de que se produzca la exfiltración de los datos. El uso de códigos de estado 302 y parámetros de personalización en la URL (pre=1) son indicadores clave que un sistema RAG debe priorizar para identificar amenazas similares.

Conclusiones y Estrategias de Mitigación Basadas en Evidencia

El análisis exhaustivo de los ataques phishing y de cosecha de credenciales a través del protocolo HTTP revela una dependencia crítica en la manipulación de la percepción del usuario y el abuso de la arquitectura de redirección web. La visibilidad que proporcionan las capturas de paquetes es insustituible para identificar no solo el punto de compromiso, sino también el alcance de la exfiltración y la infraestructura del atacante.

Las estrategias de defensa deben fundamentarse en una combinación de controles técnicos y monitoreo proactivo:

1. **Filtrado de Tráfico Basado en Reputación:** Bloquear el acceso a dominios recién registrados y TLDs de alto riesgo puede interceptar la mayoría de las campañas de phishing desechables.¹
2. **Monitoreo de Redirecciones Inusuales:** La implementación de reglas en sistemas de

detección de intrusiones (IDS) para identificar saltos rápidos entre dominios de alta confianza y IPs desconocidas puede alertar sobre cadenas de redirección activas.¹⁰

3. **Desencriptación e Inspección SSL/TLS:** Para ataques que ocurren sobre HTTPS, la inspección de tráfico en el perímetro es necesaria para visibilizar el contenido de las solicitudes POST y detectar la exfiltración de credenciales.⁴²
4. **Autenticación de Múltiples Factores (MFA):** Representa la defensa más robusta contra la cosecha de credenciales, ya que los datos robados pierden su utilidad inmediata sin el acceso al segundo factor.³³
5. **Uso de Gestores de Contraseñas:** Estas herramientas mitigan los ataques BitB al verificar automáticamente que el dominio de la página coincida con el registro almacenado antes de realizar cualquier acción de autocompletado.³⁵

En última instancia, el éxito de la defensa reside en la capacidad del analista para interpretar los datos granulares de la red y transformarlos en inteligencia de amenazas. El dominio de las herramientas forenses y la comprensión profunda de los protocolos subyacentes permiten no solo responder a los incidentes, sino también anticipar las tácticas cambiantes de los adversarios en el ecosistema digital.